UNIVERSITI TEKNOLOGI MARA
MARKING SCHEME

COURSE	:	COMPUTER SECURITY
COURSE CODE	:	CSC662
EXAMINATION	:	OCTOBER 2026 (MOCK)
TIME	:	3 HOURS

MARKING SCHEME NOTES

1. This marking scheme accompanies the CSC662 mock paper (October 2026). Computed answers show working; theory answers are supported by lecture slides (not lecturer-marked) with a verbatim quote and slide citation.

2. Supported theory marking points quote the lecture decks; any unresolved slot would remain a visible placeholder.

3. Part A = 10 x (2 + 6); Part B = 2 x (5 + 5); total = 100 marks.

4. Computed: 0 slot(s). Supported theory: 24 slots. Placeholders: 0. Questions and answers are for local study use only.

5. Near-copy rejection used all 35 past papers; style widening is recorded per slot.

FOR MARKERS' USE ONLY

This marking scheme consists of 15 printed pages

© Hak Cipta Universiti Teknologi MARA

CSC662 - MARKING SCHEME (MOCK OCTOBER 2026)

Labels: computed / supported by lecture slides (not lecturer-marked) / placeholder. No official marking scheme exists for the real CSC662 papers; this is generated for the mock.

Entailment labels: supported = the quote directly supports the marking point (or the point passed the stem-overlap gate without an LLM check); partly supported = the quote supports part of the point or is ambiguous; not supported = the quote does not support the point. Only 'not supported' points triggered regeneration.

Part A: 10 x (2 + 6) = 80 marks. Part B: 2 x (5 + 5) = 20 marks. Total: 100 marks. Slots: 0 computed, 24 supported by lecture slides, 0 placeholder.

Methods: computed answers use verified solvers. Theory answers are supported by lecture slides (not lecturer-marked). Each marking point carries a verbatim quote, a deck/slide/chunk citation and a term-overlap score; low overlap is flagged for human review. Sources are restricted to the slot topic's allowed decks, and a slide is not reused across questions where an alternative exists.

PART A - QUESTION 1

A1a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain the difference between morals, ethics and laws.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
1	Morals are described as traditions of belief concerning right and wrong conduct, forming the foundation of social behaviour.	"Morals are traditions of belief about right and wrong conduct and "doing what is morally right" is the bedrock of our social behavior"	071 - Ethics and Computer Security, slide 5 071 - Ethics and Computer Security::s05::1	supported (stem gate)	0.64
2	Laws are formal rules of conduct imposed by a sovereign authority such as a government on its subjects or citizens.	"Laws are formal rules of conduct that a sovereign authority, such as a government, imposes on its subjects or citizens"	071 - Ethics and Computer Security, slide 5 071 - Ethics and Computer Security::s05::1	supported (stem gate)	1.00

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 071 - Ethics and Computer Security, slide 5

A1b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain six requirements that a professional code of ethics and conduct, such as the ACM code, places on computing professionals.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
1	The professional must aim for high quality in the processes and products of their professional work.	"Strive to achieve high quality in both the processes and products of professional work."	071 - Ethics and Computer Security, slide 12 071 - Ethics and Computer Security::s12::1	supported (stem gate)	0.75
2	The professional must uphold strong levels of competence, conduct and ethical practice.	"Maintain high standards of professional competence, conduct, and ethical practice."	071 - Ethics and Computer Security, slide 12 071 - Ethics and Computer Security::s12::1	supported (stem gate)	0.56

© Hak Cipta Universiti Teknologi MARA

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
3	The professional must be aware of and comply with the rules that govern their professional work.	"Know and respect existing rules pertaining to professional work."	071 - Ethics and Computer Security, slide 12 071 - Ethics and Computer Security::s12::1	supported	0.43 LOW
4	The professional must limit their work to areas in which they are competent.	"Perform work only in areas of competence."	071 - Ethics and Computer Security, slide 12 071 - Ethics and Computer Security::s12::1	supported	0.43 LOW
5	The professional must contribute to society and human well-being, recognising that all people are stakeholders in computing.	"Contribute to society and to human well-being, acknowledging that all people are stakeholders in computing."	071 - Ethics and Computer Security, slide 11 071 - Ethics and Computer Security::s11::1	supported (stem gate)	0.73
6	The professional must treat others fairly and act so as not to discriminate.	"Be fair and take action not to discriminate."	071 - Ethics and Computer Security, slide 11 071 - Ethics and Computer Security::s11::1	supported	0.38 LOW

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 071 - Ethics and Computer Security, slide 11; 071 - Ethics and Computer Security, slide 12

PART A - QUESTION 2

A2a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

List two characteristics of Trojan horses as described in the lecture.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
1	Trojans replicate themselves and steal information or harm the host system.	"trojans are malicious programs that replicate themselves and steal information or harm the host computer system"	051 - Software Security, slide 12 051 - Software Security::s12::1	supported (stem gate)	1.00
2	Trojans disguise themselves as useful or benign programs.	"They usually masquerade as helpful or harmless programs"	051 - Software Security, slide 12 051 - Software Security::s12::1	supported	0.20 LOW

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 051 - Software Security, slide 12

A2b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Refer to your answer in (a). Explain six techniques by which malware infects programs or propagates, and the impact of the hidden components it installs.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
1	A virus can infect a COM executable by appending its virus body to the program.	"Append a virus body to a program"	051 - Software Security, slide 9 051 - Software Security::s09::1	supported (stem gate)	0.50
2	The virus saves the original program entry point inside its own virus body.	"Save an entry point to a program in a virus body"	051 - Software Security, slide 9 051 - Software Security::s09::1	supported (stem gate)	0.67

© Hak Cipta Universiti Teknologi MARA

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
3	For EXE files, the virus overwrites the program header so that the entry point switches to the virus.	"Over write a program header to switch the entry point to a virus"	051 - Software Security, slide 10 051 - Software Security::s10::1	supported (stem gate)	0.67
4	After running, the virus jumps back to the original entry point so the host program still executes.	"Jump to the original entry point during execution"	051 - Software Security, slide 10 051 - Software Security::s10::1	supported	0.42 LOW
5	A rootkit hides malicious processes and software so the attacker keeps privileged remote access.	"Rootkits are a type of malware that mask malicious processes and software in the infected systems to ensure privileged remote access."	051 - Software Security, slide 13 051 - Software Security::s13::1	supported (stem gate)	0.70
6	Spyware steals user logins and passwords, records sites visited and logs keystrokes, leading to identity theft.	"They steal user logins and passwords, document sites visited, log keystrokes and even redirect browsers to unwanted sites."	051 - Software Security, slide 13 051 - Software Security::s13::1	supported (stem gate)	0.61

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 051 - Software Security, slide 10; 051 - Software Security, slide 13; 051 - Software Security, slide 9

PART A - QUESTION 3

A3a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

List two formal security models named in the lecture and state the focus of each.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
1	The Bell-La Padula (BLP) model is identified as a formal security model concerned with access control.	"Bell-La Padula (BLP) model: access control only"	024 - Formal Security Model, slide 5 024 - Formal Security Model:: s05::1	supported (stem gate)	0.67
2	The Chinese Wall model is identified as a formal security model aimed at identifying conflicts of interest.	"Chinese Wall model: identification of conflicts of interest"	024 - Formal Security Model, slide 5 024 - Formal Security Model:: s05::1	supported (stem gate)	0.62

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 024 - Formal Security Model, slide 5

A3b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Describe six aspects of access control structures, covering the access control matrix, access control lists and capabilities, and the requirements such structures must satisfy.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
1	Access control structures are the mechanisms used to implement access policies.	"Access control structures are mechanisms for implementing access policies:"	023 - Access Control and Authorization, slide 7 023 - Access Control and Authorization::s07:: 1	supported (stem gate)	1.00

© Hak Cipta Universiti Teknologi MARA

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
2	The access control matrix is identified as one basic control structure.	"ACM is a basic control structure."	023 - Access Control and Authorization, slide 8 023 - Access Control and Authorization::s08::1	supported (stem gate)	0.60
3	An access control list is an object-centred description of access rights.	"ACL is an object-centered description of access rights:"	023 - Access Control and Authorization, slide 10 023 - Access Control and Authorization::s10::1	supported (stem gate)	0.67
4	Capabilities are listed as one of the structures for implementing access policies.	"Capabilities (C-List)"	023 - Access Control and Authorization, slide 7 023 - Access Control and Authorization::s07::1	partly supported	0.20 LOW
5	A required property of access control structures is the ability to express control policies.	"an ability to express control policies"	023 - Access Control and Authorization, slide 7 023 - Access Control and Authorization::s07::1	supported (stem gate)	0.50
6	Access control structures must also provide verifiability of correctness, scalability and manageability.	"verifiability of correctness. scalability and manageability"	023 - Access Control and Authorization, slide 7 023 - Access Control and Authorization::s07::1	supported	0.30 LOW

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 023 - Access Control and Authorization, slide 10; 023 - Access Control and Authorization, slide 7; 023 - Access Control and Authorization, slide 8

PART A - QUESTION 4

A4a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

State the impact of a disclosure threat and the impact of a disruption threat.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
1	A disclosure threat causes unauthorized access to information, harming confidentiality.	"Disclosure - unauthorized access to information"	011 - Introduction to Computer Security, slide 10 011 - Introduction to Computer Security::s10::1	supported (stem gate)	0.50
2	A disruption threat interrupts or prevents correct operation, harming availability.	"Disruption - interruption or prevention of correct operation"	011 - Introduction to Computer Security, slide 10 011 - Introduction to Computer Security::s10::1	supported (stem gate)	0.62

© Hak Cipta Universiti Teknologi MARA

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 011 - Introduction to Computer Security, slide 10

A4b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Discuss the Samy worm as a case study of XSS malware by describing six aspects of how it operated and spread.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
1	The worm injected JavaScript into a user profile using document.body.innerHTML.	"Inject Javascript into a user profile using document.body.innerHTML"	052 - Web Security, slide 15 052 - Web Security::s15::1	supported (stem gate)	0.78
2	It obtained the list of a user's heroes by performing a GET on a user profile.	"Get the list of user's heros by using a GET on a user profile"	052 - Web Security, slide 15 052 - Web Security::s15::1	supported (stem gate)	0.50
3	It added Samy as a friend field by performing XML-HTTP on the addFriends page.	"Add Samy as a field by performing XML-HTTP on the addFriends page"	052 - Web Security, slide 15 052 - Web Security::s15::1	supported (stem gate)	0.78
4	Any visitor to an infected user's page had their profile and friends list infected with the JavaScript and with Samy.	"Any user who visits an infected user's page will gets profile infected with Javascript and his friends list infected with Samy"	052 - Web Security, slide 15 052 - Web Security::s15::1	supported (stem gate)	0.70
5	The infection eventually reached about 1,000,000 MySpace profiles.	"Eventually about 1,000,000 MySpace profiles were infected."	052 - Web Security, slide 15 052 - Web Security::s15::1	supported (stem gate)	0.71
6	The worm exploited the general XSS weakness that any web application returning unfiltered user input is a potential XSS vulnerability.	"Any web application that returns user input without filtering is a potential XSS vulnerability!"	052 - Web Security, slide 13 052 - Web Security::s13::1	supported (stem gate)	0.64

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 052 - Web Security, slide 13; 052 - Web Security, slide 15

PART A - QUESTION 5

A5a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain how a chain of trust is established in Trusted Computing using the TPM.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
1	The chain of trust is the core idea of the Trusted Computing architecture, where each stage measures and validates the next one.	"The core idea of the Trusted Computing architecture Each stage measures and validates the next one"	073 - Trusted Computing, slide 8 073 - Trusted Computing::s08::1	supported (stem gate)	0.82
2	The measurements produced during this process are stored in Platform Configuration Registers (PCRs) on the TPM.	"Measurements go into Platform Configuration Registers (PCRs) on the TPM"	073 - Trusted Computing, slide 8 073 - Trusted Computing::s08::1	supported (stem gate)	0.60

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 073 - Trusted Computing, slide 8

A5b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain six components and functions of the NGSCB architecture, covering both the Nexus and the Nexus

© Hak Cipta Universiti Teknologi MARA

Computing Agent.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
1	The Nexus is a security kernel that is authenticated during boot.	"Security kernel, authenticated on boot"	073 - Trusted Computing, slide 14 073 - Trusted Computing::s14::1	supported (stem gate)	0.67
2	The Nexus authenticates trusted programs.	"Authenticates trusted programs"	073 - Trusted Computing, slide 14 073 - Trusted Computing::s14::1	supported (stem gate)	0.75
3	The Nexus provides the application interface to the TPM.	"Application interface to TPM"	073 - Trusted Computing, slide 14 073 - Trusted Computing::s14::1	supported (stem gate)	0.60
4	The Nexus does not trust the operating system.	"Does not trust OS"	073 - Trusted Computing, slide 14 073 - Trusted Computing::s14::1	supported (stem gate)	0.50
5	The Nexus Computing Agent is a trusted software component.	"Trusted software component"	073 - Trusted Computing, slide 15 073 - Trusted Computing::s15::1	supported	0.40 LOW
6	The Nexus Computing Agent runs in a trusted mode that communicates with the Nexus.	"Runs in trusted mode that communicates with Nexus"	073 - Trusted Computing, slide 15 073 - Trusted Computing::s15::1	supported (stem gate)	0.71

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 073 - Trusted Computing, slide 14; 073 - Trusted Computing, slide 15

PART A - QUESTION 6

A6a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain how NIDS sensors should be positioned in a network and why.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
1	Sensors should be placed deliberately so that the organisation's most valuable assets are defended.	"Place IDS sensors strategically to defend most valuable assets"	062 - Intrusion Detection System, slide 7 062 - Intrusion Detection System::s07::1	supported (stem gate)	0.67
2	A typical sensor location is immediately inside the firewall, so traffic that has passed the perimeter is monitored.	"Just inside the firewall"	062 - Intrusion Detection System, slide 7 062 - Intrusion Detection System::s07::1	partly supported	0.18 LOW

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 062 - Intrusion Detection System, slide 7

A6b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Discuss six preventive network security mechanisms that an organisation can deploy, explaining the

© Hak Cipta Universiti Teknologi MARA

protective role of each mechanism.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
1	A firewall protects the network by controlling incoming and outgoing traffic according to predetermined security policies.	"Control incoming and outgoing traffic on network with predetermined security policies."	061 - Network Security, slide 3 061 - Network Security::s03::1	supported (stem gate)	0.73
2	A proxy server improves data security and network performance by acting as a firewall and web filter, sharing network connections and caching data.	"Proxy servers act as a firewall and web filter, provide shared network connections, and cache data to speed up common requests."	061 - Network Security, slide 3 061 - Network Security::s03::1	supported (stem gate)	0.79
3	Network segmentation establishes boundaries between network segments whose computing assets share a common function, risk or role.	"Boundaries between network segments where computing assets within the segment have a common function, risk or role within an organization."	061 - Network Security, slide 3 061 - Network Security::s03::1	supported (stem gate)	0.77
4	A remote access VPN gives individual hosts or clients remote and secure access to the organisation's network.	"Provides remote and secure access to an organization network to individual hosts or clients"	061 - Network Security, slide 4 061 - Network Security::s04::1	supported (stem gate)	0.78
5	Zero Trust Network Access restricts each user to only the access and permission needed to fulfil that user's role.	"A user should only has access and permission that required to fulfill the role"	061 - Network Security, slide 4 061 - Network Security::s04::1	supported (stem gate)	0.55
6	IDS/IPS mechanisms detect or prevent network attacks such as brute force attacks, Denial-of-Service attacks and exploits of network vulnerabilities.	"To detect or prevent the network security attacks such as brute force attacks, Denial-of-Service attacks and exploits of network vulnerabilities."	061 - Network Security, slide 4 061 - Network Security::s04::1	supported (stem gate)	0.79

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 061 - Network Security, slide 3; 061 - Network Security, slide 4

PART A - QUESTION 7

A7a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain two limitations of passive intrusion detection systems in handling attacks.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
1	A passive detection system can only log and alert when it identifies an attack, rather than intervening.	"Can take passive action (logging and alerting) when an attack is identified"	062 - Intrusion Detection System, slide 29 062 - Intrusion Detection System::s29::1	supported (stem gate)	0.50
2	A passive detection system is unable to actively halt an attack that is currently underway.	"Cannot take active actions to stop an attack in progress"	062 - Intrusion Detection System, slide 29 062 - Intrusion Detection System::s29::1	supported	0.22 LOW

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 062 - Intrusion Detection System, slide 29

A7b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Compare a threat and an attack as security concepts, and contrast how misuse-based and anomaly-based detection models each counter them, noting one strength and one weakness of each model.

© Hak Cipta Universiti Teknologi MARA

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
1	A threat is only a potential violation of security, not an actual one.	"A threat is a "potential" violation of security"	011 - Introduction to Computer Security, slide 9 011 - Introduction to Computer Security::s09::1	supported (stem gate)	0.57
2	An attack is the actual violation of security, i.e. the realised exploitation.	"Attacks: The actual violation of security"	011 - Introduction to Computer Security, slide 9 011 - Introduction to Computer Security::s09::1	supported (stem gate)	0.67
3	Misuse detection represents attacks as patterns or signatures so that variations of the same attack can be recognised.	"there are ways to represent attacks in the form of a pattern or a signature so that even variations of the same attack can be detected"	062 - Intrusion Detection System, slide 17 062 - Intrusion Detection System:: s17::1	supported (stem gate)	0.80
4	A weakness of misuse detection is that it is of little use against unknown attack methods.	"They can detect many or all known attack patterns, but they are of little use for unknown attack methods."	062 - Intrusion Detection System, slide 17 062 - Intrusion Detection System:: s17::1	supported (stem gate)	0.62
5	A strength of predictive-pattern anomaly detection is that rule-based sequential patterns can detect anomalous activities that traditional methods struggled with.	"Rule based sequential patterns can detect anomalous activities that were difficult with traditional methods."	062 - Intrusion Detection System, slide 25 062 - Intrusion Detection System:: s25::1	supported (stem gate)	0.71
6	A weakness of predictive-pattern anomaly detection is that intrusion scenarios not described by the rules will not be flagged.	"The problem is that some intrusion scenarios that are not described by the rules will not be flaged intrusive."	062 - Intrusion Detection System, slide 25 062 - Intrusion Detection System:: s25::1	supported	0.46 LOW

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 011 - Introduction to Computer Security, slide 9; 062 - Intrusion Detection System, slide 17; 062 - Intrusion Detection System, slide 25

PART A - QUESTION 8

A8a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

State the two stages of the biometric authentication process.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
1	The identification stage, in which master characteristics are acquired and stored.	"Identification Stage Acquisition Creation of Master characteristics Storage of Master characteristics"	072 - Biometrics and Authentication, slide 5 072 - Biometrics and Authentication:: s05::1	supported (stem gate)	0.60
2	The authentication stage, in which acquisition is repeated, compared and a decision made.	"Authentication Stage Acquisition(s) Comparison Decision"	072 - Biometrics and Authentication, slide 5 072 - Biometrics and Authentication:: s05::1	supported (stem gate)	0.67

© Hak Cipta Universiti Teknologi MARA

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 072 - Biometrics and Authentication, slide 5

A8b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain the categories of biometric technologies and the practical issues that affect their use in authentication.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
1	Biometric applications are divided into two sectors, one of which is the psychological (physiological) category covering traits such as iris, fingerprints, hand, retinal and face.	"Biometric applications available today are categorized into 2 sectors"	072 - Biometrics and Authentication, slide 4 072 - Biometrics and Authentication:: s04::1	partly supported	0.25 LOW
2	The second sector is the behavioural category, which includes voice, typing pattern and signature.	"Behavioural: Voice, Typing pattern, Signature"	072 - Biometrics and Authentication, slide 4 072 - Biometrics and Authentication:: s04::1	supported (stem gate)	0.50
3	A biometric is defined as a physiological or behavioural characteristic that can distinguish one person from another and can theoretically be used for identification or verification.	"A biometric is a physiological or behavioural characteristic of a human being that can distinguish one person from another and that theoretically can be used for identification or verification of identity."	072 - Biometrics and Authentication, slide 2 072 - Biometrics and Authentication:: s02::1	supported (stem gate)	0.91
4	Fingerprint biometrics suffer from disadvantages such as racial issues, dirt, grime and wounds, and the placement of the finger.	"Racial issues"	072 - Biometrics and Authentication, slide 7 072 - Biometrics and Authentication:: s07::1	partly supported	0.17 LOW
5	Fingerprint systems can be spoofed, so liveness detection is important.	"Can be spoofed - liveness important!"	072 - Biometrics and Authentication, slide 7 072 - Biometrics and Authentication:: s07::1	supported (stem gate)	0.57
6	Iris scanning requires no touch and overcomes the issues of retinal scanners, although contact lenses may be a problem.	"Overcomes retinal scanner issues"	072 - Biometrics and Authentication, slide 10 072 - Biometrics and Authentication:: s10::1	partly supported	0.31 LOW

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 072 - Biometrics and Authentication, slide 10; 072 - Biometrics and Authentication, slide 2; 072 - Biometrics and Authentication, slide 4; 072 - Biometrics and Authentication, slide 7

PART A - QUESTION 9

A9a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

State the four goals of access control and the role of a reference monitor.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap

© Hak Cipta Universiti Teknologi MARA

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
1	The four goals of access control are granting, limiting, preventing and revoking access.	"Goals of access control: Granting access Limiting access Preventing access Revoking access"	023 - Access Control and Authorization, slide 4 023 - Access Control and Authorization::s04::1	supported (stem gate)	1.00
2	A reference monitor is the instrument used to realize access control policies and can be deployed at all levels of the system hierarchy.	"Reference monitors are instruments for realization of access control policies. They can be deployed at all levels of system hierarchy."	023 - Access Control and Authorization, slide 18 023 - Access Control and Authorization::s18::1	supported (stem gate)	1.00

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 023 - Access Control and Authorization, slide 18; 023 - Access Control and Authorization, slide 4

A9b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

State six aspects of the Chinese Wall formal security model, covering its purpose, its simple security rule, its write rule, and how its permissions behave.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
1	The Chinese Wall policy was proposed by Brewer and Nash to address conflicts of interest.	"Brewer and Nash (1989) proposed a policy called the Chinese Wall Policy that addresses such conflicts of interest."	024 - Formal Security Model, slide 21 024 - Formal Security Model::s21::1	supported (stem gate)	1.00
2	It is classified as an access control confidentiality policy rather than an integrity policy.	"Strictly speaking, this is not an integrity policy, but an access control confidentiality policy."	024 - Formal Security Model, slide 21 024 - Formal Security Model::s21::1	supported (stem gate)	0.62
3	Under the simple security rule, a subject may access an object only if it is within the Wall or in an entirely different conflict of interest class.	"A subject s can be granted access to an object o only if the object:"	024 - Formal Security Model, slide 25 024 - Formal Security Model::s25::1	partly supported	0.27 LOW
4	Under the Chinese Wall *-property, a write is allowed only when the simple security rule also permits the access and no readable object lies in a different company dataset while containing unsanitized information.	"Write access is only permitted if: access is permitted by the simple security rule, and no object can be read which is: in a different company dataset than the one for which write access is requested, and contains unsanitized information."	024 - Formal Security Model, slide 26 024 - Formal Security Model::s26::1	supported (stem gate)	0.56
5	Permissions change dynamically, since a subject's rights depend on the history of its past accesses.	"Notice that permissions change dynamically. The access rights that any subject enjoys depends on the history of past accesses"	024 - Formal Security Model, slide 24 024 - Formal Security Model::s24::1	supported (stem gate)	0.90
6	The model is crafted to solve the specialized problem of conflicts of interest for a consultant or contractor.	"Brewer and Nash's Chinese Wall Policy is designed to address a very specific concern: conflicts of interest by a consultant or contractor."	024 - Formal Security Model, slide 27 024 - Formal Security Model::s27::1	supported	0.44 LOW

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited

© Hak Cipta Universiti Teknologi MARA

lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 024 - Formal Security Model, slide 21; 024 - Formal Security Model, slide 24; 024 - Formal Security Model, slide 25; 024 - Formal Security Model, slide 26; 024 - Formal Security Model, slide 27

PART A - QUESTION 10

A10a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain why buffer overflows arise in software and how they can be exploited.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
1	Buffer overflow occurs because string copy routines such as strcpy do not verify the length of the input before copying it into a fixed-size buffer.	"strcpy() do not check the string length"	051 - Software Security, slide 23 051 - Software Security::s23::1	supported	0.23 LOW
2	Without proper bounds checking, data written into a local buffer can spill over into the adjacent higher stack area.	"Without proper bound checking a buffer content can overspill into adjacent upper stack area."	051 - Software Security, slide 21 051 - Software Security::s21::1	supported (stem gate)	0.62

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 051 - Software Security, slide 21; 051 - Software Security, slide 23

A10b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

State six Windows security mechanisms or components and, for each, what it provides.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
1	The Security Reference Monitor in kernel mode performs ACL verification.	"Security Reference Monitor: ACL verification"	041 - Windows Security, slide 3 041 - Windows Security::s03::1	supported (stem gate)	0.50
2	The winlogon process in user mode handles user logon.	"Log-on process (winlogon): user logon"	041 - Windows Security, slide 3 041 - Windows Security::s03::1	supported (stem gate)	0.67
3	The Local Security Authority verifies and changes passwords, manages access tokens and keeps audit logs.	"Local Security Authority (LSA): password verification and change, access tokens, audit logs"	041 - Windows Security, slide 3 041 - Windows Security::s03::1	supported (stem gate)	0.75
4	The Security Accounts Manager holds the accounts database and performs password encryption.	"Security Accounts Manager (SAM): accounts database, password encryption"	041 - Windows Security, slide 3 041 - Windows Security::s03::1	supported (stem gate)	0.75
5	User Account Control introduced in Vista enforces limited user privileges.	"User Account Control (UAC, Vista): enforcement of limited user privileges"	041 - Windows Security, slide 3 041 - Windows Security::s03::1	supported (stem gate)	0.88
6	Security credentials for a subject are kept in a token, which provides a principal/subject mapping and may carry additional security attributes.	"Security credentials for a subject are stored in a token."	041 - Windows Security, slide 11 041 - Windows Security::s11::1	partly supported	0.33 LOW

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 041 - Windows Security, slide 11; 041 - Windows Security, slide 3

PART B - QUESTION 1

B1a - 5 marks - supported by lecture slides (not lecturer-marked)

© Hak Cipta Universiti Teknologi MARA

Scenario:

A small company runs a shared Linux server where staff log in with user names and passwords. After several accounts were guessed by an attacker, the administrator is asked to strengthen how passwords are protected and managed on the system.

Question:

Explain five password security controls that the administrator can apply to protect the server's user accounts.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
1	Apply access control to the password files so that stored passwords are not freely readable.	"Access control applied to password files"	022 - Identification and Authentication, slide 12 022 - Identification and Authentication:: s12::1	partly supported	0.44 LOW
2	De-activate an account automatically after several failed login attempts.	"De-activation of accounts after multiple failed logins"	022 - Identification and Authentication, slide 12 022 - Identification and Authentication:: s12::1	supported (stem gate)	0.62
3	Show the time of the last login so users can notice suspicious access.	"Displaying the time of a last login"	022 - Identification and Authentication, slide 12 022 - Identification and Authentication:: s12::1	partly supported	0.33 LOW
4	Enforce password policies, for example for the root password.	"Password policies, e.g. for root password"	022 - Identification and Authentication, slide 12 022 - Identification and Authentication:: s12::1	supported (stem gate)	0.60
5	Store passwords in encrypted form using a one-way hash function.	"Password is stored in an encrypted form using a one-way hash function:"	022 - Identification and Authentication, slide 8 022 - Identification and Authentication:: s08::1	supported (stem gate)	1.00

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 022 - Identification and Authentication, slide 12; 022 - Identification and Authentication, slide 8

B1b - 5 marks - supported by lecture slides (not lecturer-marked)

Question:

State five points about single sign-on and Kerberos that the administrator in the scenario could use to reduce staff reliance on typed passwords on the shared server.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
1	Single sign-on reduces the need for users to memorize passwords.	"Reduce the need to memorize passwords"	022 - Identification and Authentication, slide 16 022 - Identification and Authentication:: s16::1	supported (stem gate)	0.57

© Hak Cipta Universiti Teknologi MARA

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
2	Single sign-on reduces the time users spend typing passwords.	"Reduce the time spent on typing passwords"	022 - Identification and Authentication, slide 16 022 - Identification and Authentication:: s16::1	supported	0.43 LOW
3	Kerberos is a client-server single sign-on architecture.	"Client-server architectures (Kerberos, Active Directory)"	022 - Identification and Authentication, slide 16 022 - Identification and Authentication:: s16::1	supported (stem gate)	0.67
4	In Kerberos login, the user enters a user name and password at the client workstation.	"User enters his user name, U and password, P at a client workstation."	022 - Identification and Authentication, slide 19 022 - Identification and Authentication:: s19::1	supported (stem gate)	0.71
5	The hash of the user's password becomes the client's secret key.	"The hash value of his password KU = h(P) becomes a secret key of the client/user."	022 - Identification and Authentication, slide 19 022 - Identification and Authentication:: s19::1	supported (stem gate)	1.00

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 022 - Identification and Authentication, slide 16; 022 - Identification and Authentication, slide 19

PART B - QUESTION 2

B2a - 5 marks - supported by lecture slides (not lecturer-marked)

Question:

Discuss the ethical impacts of technology by examining how professional codes of ethics guide computing professionals, and evaluate the limitations of such codes in addressing ethical concerns.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
1	Professional bodies such as the ACM have established codes of ethics and professional conduct to guide members' behaviour.	"Association of Computing Machinery ACM (founded 1947) has a code of ethics and professional conduct."	071 - Ethics and Computer Security, slide 7 071 - Ethics and Computer Security::s07::1	supported	0.42 LOW
2	Other professional IT bodies, such as AITP, also promote ethical standards and professional development among their members.	"provides quality IT-related education, information on relevant IT issues, and forums for networking with experienced peers and other IT professionals."	071 - Ethics and Computer Security, slide 7 071 - Ethics and Computer Security::s07::1	partly supported	0.17 LOW
3	Ethics can be understood as a documented set of acceptable behaviours for a professional or social group.	"Documented set of acceptable behaviors for professional or social groups."	071 - Ethics and Computer Security, slide 6 071 - Ethics and Computer Security::s06::1	supported (stem gate)	0.60
4	A code of ethics identifies specific actions as either appropriate or inappropriate for members of the group.	"Identifies specific actions as appropriate or inappropriate."	071 - Ethics and Computer Security, slide 6 071 - Ethics and Computer Security::s06::1	supported	0.38 LOW

© Hak Cipta Universiti Teknologi MARA

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
5	A limitation of ethical codes is that they may not reflect the ethics of every member of the group.	"May not reflect the ethical of every member of the group."	071 - Ethics and Computer Security, slide 9 071 - Ethics and Computer Security::s09::1	supported (stem gate)	0.70

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 071 - Ethics and Computer Security, slide 6; 071 - Ethics and Computer Security, slide 7; 071 - Ethics and Computer Security, slide 9

B2b - 5 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain five ways an organization can demonstrate responsibility for privacy when handling personal information, referring to the ethical dimensions of information use.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
1	The organization must protect individuals' personal information as a privacy obligation.	"Protecting one's personal information"	071 - Ethics and Computer Security, slide 13 071 - Ethics and Computer Security::s13::1	partly supported	0.38 LOW
2	The organization must ensure the accuracy and fidelity of the information it holds.	"Deals with authentication and fidelity of information"	071 - Ethics and Computer Security, slide 13 071 - Ethics and Computer Security::s13::1	partly supported	0.29 LOW
3	The organization must address who owns information about individuals and how it may be sold or exchanged.	"Deals with who owns information about individuals and how information can be sold and exchanged"	071 - Ethics and Computer Security, slide 13 071 - Ethics and Computer Security::s13::1	supported (stem gate)	0.64
4	The organization must govern what information a person has the right to obtain about others and how that information may be used.	"Deals with what information a person has the right to obtain about others and how the information can be used"	071 - Ethics and Computer Security, slide 13 071 - Ethics and Computer Security::s13::1	supported (stem gate)	0.64
5	Information specialists within the organization have definite responsibilities to perform within ethical, moral and legal constraints.	"Users in general, and information specialists in particular, have definite responsibilities in terms of performing within ethical, moral, and legal constraints"	071 - Ethics and Computer Security, slide 3 071 - Ethics and Computer Security::s03::1	supported (stem gate)	0.92

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 071 - Ethics and Computer Security, slide 13; 071 - Ethics and Computer Security, slide 3

End of marking scheme.

© Hak Cipta Universiti Teknologi MARA